What a registry has to carry for a hiring agent

Four requirements, coverage and open gaps · Technical review draft v0.2 · 30 October 2026

Prasanna Bableshwar, Principal Software Engineer, Atlassian (personal capacity)

Status: v0.2, updated in place 30 October 2026. This version folds in the chair's clarifications of 30 October on how the registry operates today, and the pointer formulation agreed in the same thread. Comments on this draft.

Purpose. A hiring agent screens candidates, requests documents and prepares decisions that affect people's livelihoods. When something is challenged, an employer has to reconstruct who stood behind the agent, what it was allowed to do, what it asked people for, and what authorization was in force on the day. A registry is useful to that employer only if a third party can answer those questions from what the registry carries. This note states the four requirements that follow, marks how far the ARIA specification as published covers each, and names what is still open. Marks are coverage marks on the requirements, not conformance grades.

The four requirements

Requirement	What the registry must carry	Coverage in ARIA as specified	Open gap
1. Accountable chain	The person and organization answerable for the agent: an identified person behind it (L1), proof that person can bind an organization (L3), and the agent bound to that person.	Covered in the specification.	L1–L3 specified, not issued. Nothing live to test against.
2. Scope and escalation	What the agent may decide, in the namespace:resource:action grammar, and what it must escalate: the designated escalation role, the scope and the policy version.	Scope grammar covered. Agent Trust Policy mechanism is marked planned. Section 6 approval tiers cover approval of issuance, not escalation of a prepared decision.	The escalation fields: whether the credential carries the designated role, the scope and the policy version is the question for the group. AAE-02 covers deferral and ratification on the receiver side; it doesn't name the delivery destination or the deadline.
3. Evidence requests	A pointer to the policy that bounds what the agent may ask people for. The evidence itself never sits in a registry.	Not covered.	Pointer form agreed in discussion: URL plus SHA-256 digest, version-bound, fixed as an annex to this note. The pointer can travel with what the agent presents; the registry's published value is the reference a receiver checks against.
4. State at a past date	What authorization was in force on a given date, in a form a relying party can check later and offline.	Not met as the registry operates today. Current state only. A change is a manual revocation and a new issuance under the same DID. The lifecycle is	The relying-party flow, and the previous-credential link: it is in the spec, the operator is questioning whether it is relevant, and this note's position is that it

		recorded in the Trust Ledger, which is not publicly available, and whether or how it should be is undecided. SCITT is a substrate a ledger could be built on, with the four limits below.	is load-bearing (see closing item 4). Candidate construction: Zhao's signed state-at-date bundle under three conditions, with Barbosa's interval checkpoint meeting the third.

Requirement 4 in detail

SCITT mark. IETF SCITT (RFC 9943, RFC 9942, SCRAPI) specifies an append-only transparency service: statements cannot be modified, deleted or reordered once registered; receipts are verifiable offline without access to the service; the service authenticates issuers and applies registered policies. Against requirement 4, four limits in the RFC text: (1) registration policy content is left to the operator, so the lifecycle rules a hiring registry needs are not in the spec; (2) statements are opaque to the service, there is no credential lifecycle and no state-at-a-date object, only entry registration and single-entry retrieval; (3) there is no completeness statement, an issuer may withhold statements and nothing attests that none are missing; (4) revocation strategies for compromised keys are out of scope.

From the running side. Dick Brooks, who operates a SCITT-based registry, agreed on the list that the policy and lifecycle gaps are real, and that in his deployment the ledger holds the statement and its evidence hash while lifecycle state lives in the operator's own data store. His registry also answers current state only: a registered object is trusted until an explicit action makes it untrusted. Both registries in this discussion answer "trusted now". Neither yet answers "what was in force then".

The third condition. Zhao: the bundle must state, for the interval it covers, that no revocation event was recorded in it. The word is recorded, not occurred. Without that, "not revoked" and "revocation not logged" are indistinguishable. Accepted.

The checkpoint construction. Barbosa: the operator signs a per-interval checkpoint (credential identifier, the interval, ledger positions at both ends with head hash and sequence number, and the events for that credential inside the interval, possibly none) and timestamps the checkpoint digest when written (RFC 3161, OpenTimestamps). A receiver checks the hash chain runs unbroken between the two positions. One limit, stated by Barbosa and agreed: a revocation the operator decided but never logged can't be shown this way. That sits with the accountable chain in requirement 1, not with the ledger. The construction is with the ARIA technical implementation for review.

Operating factors. From the same operator's stated experience running a registry in production: governance a relying party can inspect, availability around the clock, registration checks under a second, protection against insider tampering, and records an auditor can work from. Carried here as one operator's experience. A later version should give these their own section; trust scoring and monitoring are left out as product-specific.

What would close this out

1. ARIA side: confirm or correct the four marks. In particular, whether an escalation role belongs in the credential, in the Agent Trust Policy, or is carried somewhere else.
2. Group: decide the escalation fields in requirement 2 — designated role, scope and policy version — as credential content or not.

3. Group: the evidence-policy pointer for requirement 3, fixed as an annex to this note: fields, digest algorithm, the registry's published value as the reference.
4. ARIA side: the previous-credential link. This note's position: keep it. Without it, a revoked credential and its replacement are two disconnected records and supersession can't be told from two unrelated credentials.
5. ARIA side: whether the Trust Ledger becomes public, and if so the relying-party flow for obtaining historical state and checking it offline.
6. Group: decide whether SCITT is the substrate registries here build the ledger function on, with a lifecycle profile on top, or whether the group specifies its own.
7. Operators: one live L1 and one live L3 credential, so requirement 1 stops being a paper mark.
8. Group: adopt the signed state-at-date bundle with the checkpoint construction as the candidate requirement 4 flow, and specify it.

Evidence status

The requirement 4 mark rests on the chair's own statement of how the registry operates today (list, 30 October 2026), which supersedes his 26 October description. The remaining marks are against the published ARIA specification text. L1–L3 are specified and not issued, so live behaviour is untested. The SCITT limits are from the RFC and SCRAPI texts. Operator statements are from the list discussion of 29–30 October 2026 and are attributed where used. Nothing here is a conformance finding.